Effat University

SPRING 2026

NoorPay GRC Consulting Engagement

External Risk Assessment, Compliance Gap Analysis & Incident Response Plan

Course: CS 3178

Instructor and Supervisor: Dr. Sohail Khan

Students:

Natali Soukh

Zainab Taha

Date of Submission

[02/05/2026]

Effat University

SPRING 2026

Executive Summary

NoorPay is a Saudi fintech company managing more than half a million transactions each day for Saudi Arabian and international clients. As external GRC consultants, our team carried out a structured risk assessment, compliance gap analysis according to GDPR and Saudi PDPL, and an Incident Response Plan development during this engagement.

The risk assessment has highlighted 10 key risks for NoorPay, where the top two risks that have been categorized as Critical (risk rating 25/25) are the unresolved and unreported 2024 data breach incident and the imminent failure of regulatory compliance, along with the third risk that is classified as High (risk rating 20/25). Currently, NoorPay does not have a risk register, a CISO, a cloud security policy, or an Incident Response Plan, making it vulnerable to threats across all categories at once.

Regarding compliance, NoorPay is classified as Non-Compliant with all six analyzed requirements according to both GDPR and Saudi PDPL. The biggest challenge in this case is the 2024 data breach involving 12,000 clients whose personal details and IDs were affected. This data breach did not notify SDAIA and any EU supervisory authority, thus making it illegal.

Three strategic recommendations for NoorPay management include:

1. Submit a retroactive data breach notification to SDAIA as soon as possible, since each day that passes is another day that the firm will be vulnerable to legal ramifications.
2. Hire an interim Data Protection Officer who can start recording the lawful basis behind every form of data processing.
3. Require multi-factor authentication in all cloud-based accounts, which is one of the most important immediate technical measures.

1. Risk Assessment

1.1 Methodology

The above risk analysis has been done according to the NIST SP 800-30 Revision 1 methodology, which offers a systematic method of analyzing and prioritizing information security risks. Likelihood values between 1 and 5 and Impact values between 1 and 5 have been used for each individual risk with justification for each value. The risk rating can be computed by multiplying Likelihood and Impact, which ranges from low (1-8) to medium (9-14) to high (15-25). There are ten unique risk scenarios under three mandatory categories: technology risks, people/process risks, and compliance/regulatory risks.

1.2 Risk Identification and Analysis

For each identified risk, a clear risk statement was formulated along with the impacted asset, potential source of threat, likelihood and impact ratings with justification, and the risk rating.

1.2.1 Risk Categories

- Technology Risks: R-01, R-04, R-07, R-09, R-10
- People/Process Risks: R-03, R-05, R-06
- Compliance/Regulatory Risks: R-02, R-08

Table 1: NoorPay Risk Register

Risk ID	Risk Description	Affected Asset	Threat Source	L	I	Rating	Level
R-01	Unauthorized access to cloud-hosted customer data via misconfigured storage or stolen credentials	Cloud-hosted customer database (500,000+ records)	External attacker exploiting cloud misconfiguration	4	5	20	High
R-02	Repeat data breach following the unreported and uninvestigated 2024 incident	Customer financial records, transaction histories, identity documents	External attacker — original vector unknown and unaddressed	5	5	25	Critical
R-03	Absence of IRP enabling any breach to escalate without containment or notification	All NoorPay systems and customer data	Internal process failure — no governance structure	4	4	16	High
R-04	Data exposure via unvetted third-party cloud provider with no DPA or data residency confirmation	Customer PII stored and processed by cloud provider	Third-party vendor failure or unauthorized cross-	3	4	12	Medium

			border transfer				
R-05	Insider privilege abuse enabled by absence of access controls and audit logging	Customer financial data and identity documents	Malicious or negligent insider across 250 employees	3	4	12	Medium
R-06	Inability to fulfill data subject rights under GDPR Art. 17 and PDPL Art. 12	Customer personal data processing records	Regulatory enforcement triggered by customer complaint or audit	4	3	12	Medium
R-07	Phishing attack compromising employee credentials and granting cloud data access	Employee accounts providing access to cloud systems	External attacker using phishing or spear-phishing	4	4	16	High
R-08	SDAIA and SAMA regulatory audit failure due to zero documentation and unreported 2024 breach	NoorPay operating license and business continuity	Regulatory authority (SDAIA, SAMA, EU supervisory authority)	5	5	25	Critical
R-09	Interception of unencrypted payment and identity data transmitted to cloud provider	Payment and identity data in transit	External attacker conducting man-in-the-middle interception	3	4	12	Medium
R-10	Operational disruption with no BCP/DRP for 500,000 daily transactions	Payment processing platform and all active transactions	System failure, ransomware attack, or cloud outage	3	4	12	Medium

Table 1 is the list of all risk factors for NoorPay. The risks are categorized according to the risk scores that have been determined based on the context of NoorPay, which is a fintech organization without any security controls, without a CISO, and with an unreported breach of security. According to Appendix A, CISO Assistant was utilized in determining the 10 risks.

1.3 Risk Prioritization

1.3.1 Top Three Risks

The below-listed three risks pose the maximum danger to NoorPay considering their severity levels and the company's working environment:

R-02 — Repeat Data Breach (Risk Rating: 25/25 — Critical)

This is the most severe risk due to the presence of an actual past incident with no follow-up response measures. The original breach of 2024 has not yet been investigated, which means that

the same weakness persists now. Being a payment service provider managing financial and personal information, NoorPay will incur multiple penalties from different regulatory bodies at once in case of a second breach without reporting the prior one to SDAIA and the EU.

R-08 — Regulatory Audit Failure (Risk Rating: 25/25 — Critical)

The risk posed here is unique in nature since the audit is going to take place soon. NoorPay is unable to submit any documents regarding compliance with requests made by the auditors. The impact goes beyond the mere cost of non-compliance since any suspension by the regulatory authority means that all operations of the company will be brought to a standstill.

R-01 — Unauthorized Cloud Access (Risk Rating: 20/25 — High)

This threat poses structural risks since there is absolutely nothing that can detect its occurrence. There will be no way for NoorPay to know that a cyberattack is underway since cloud misconfiguration attacks are the most frequent method of initial access for fintech cyberattacks. This risk is compounded by the fact that there are no cloud security policies or CISOs.

1.3.2 Risk Heat Map

The risk heat map for the 10 risks is represented in the following Figure 1 below. The critical point located at the top right corner of the graph (Likelihood 5 and Impact 5) belongs to Risks R-02 and R-08, whereas Risk R-01 belongs to the high-risk zone (Likelihood 4, Impact 5).

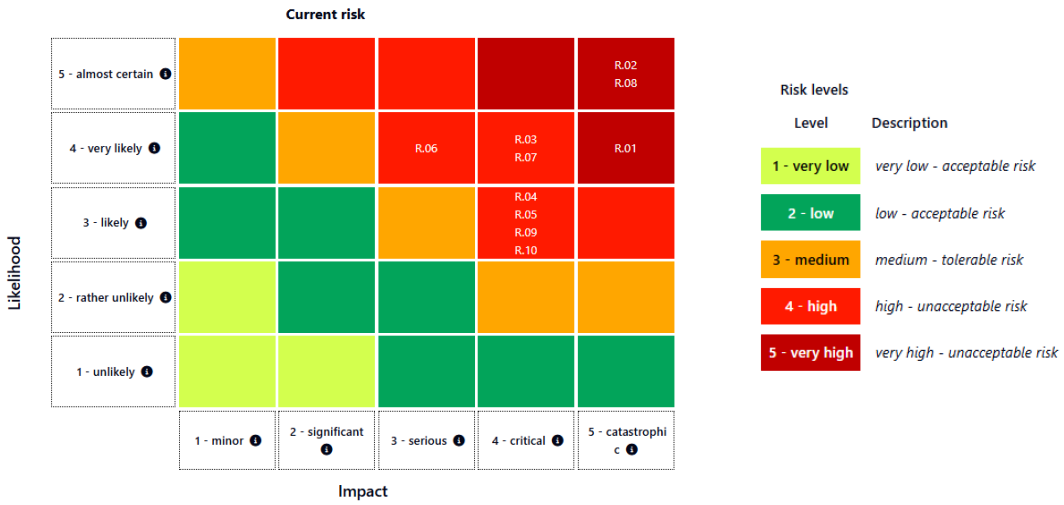


Figure A-1: NoorPay 5×5 Risk Heat Map generated in CISO Assistant showing all 10 risk scenarios plotted by likelihood and impact.

1.4 CISO Assistant — Risk Assessment

The CISO Assistant tool was employed for the purpose of capturing the full risk register for NoorPay. The tool was utilized to enter all ten scenarios, which comprised the risk name, description, threat classification, risk source, probability score, impact score, and rationale. The tool automatically generated a risk heat map using the 5×5 ISO-27005 risk matrix. Screenshots are presented in Appendix A.

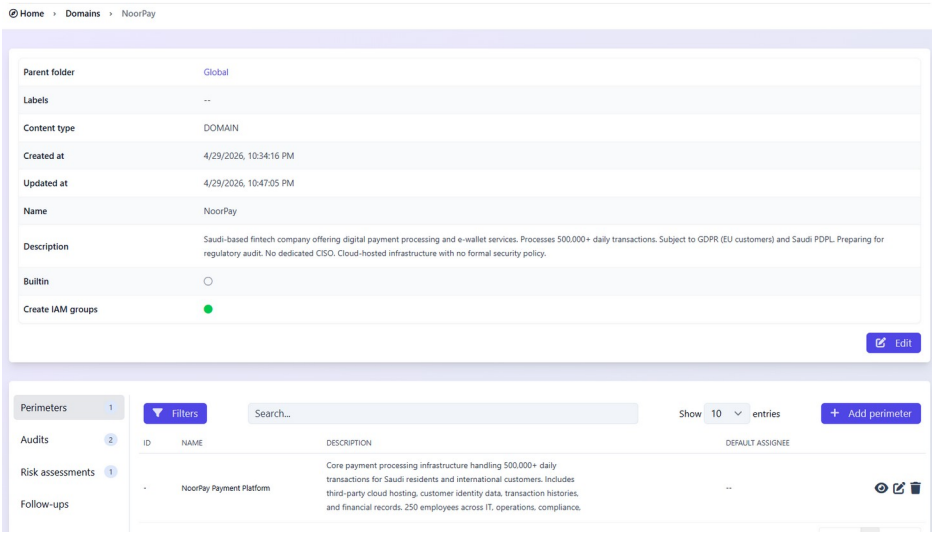


Figure A-2: NoorPay domain overview in CISO Assistant showing 1 perimeter, 2 audits, and 1 risk assessment.

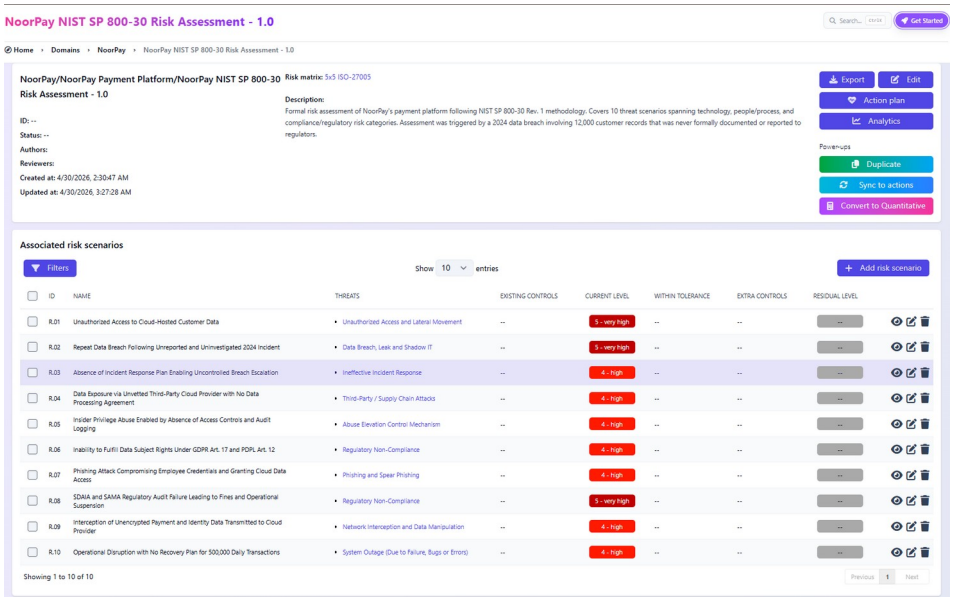


Figure A-3: All 10 NoorPay risk scenarios documented in CISO Assistant with threat classifications and risk levels.

2. Compliance Gap Analysis

2.1 Framework Selection and Mapping

Two sets of regulations were analyzed: first, GDPR (EU 2016/679), and secondly, PDPL (Royal Decree M/19, 2021). Six provisions of each regulation were chosen in respect of operational relevance to NoorPay as a Saudi-based fintech organization which processes financial data and personal documents of the company's Saudi-based and EU customers.

GDPR applies to NoorPay since personal data of the company's EU customers are processed in connection with the provision of international payment services. Selected articles are the basic set of controller's obligations to be met prior to processing the first record.

Saudi PDPL applies to NoorPay since it is a Saudi-based company processing personal and financial data of Saudi residents. Full responsibility of NoorPay before SDAIA, as well as an existing confirmed violation resulting from the unreported 2024 incident, was identified.

2.2 Gap Analysis

Table 2: NoorPay Compliance Gap Analysis

Regulation	Requirement	Current Status	Evidence from Scenario	Gap Description
GDPR	Art. 6 — Lawful Basis for Processing	Non-Compliant	No Records of Processing Activities exist; no processing documentation of any kind	All EU customer data processing lacks a documented legal justification under any Art. 6 ground
GDPR	Art. 25 — Data Protection by Design	Non-Compliant	No DPIA process; no privacy controls in system design; no data minimization defaults	Systems were built and deployed without any GDPR privacy considerations embedded
GDPR	Art. 30 — Records of Processing Activities	Non-Compliant	No data inventory, no processing register, no retention schedule documented	Complete absence of the foundational GDPR documentation that all auditors request first
GDPR	Art. 32 — Security of Processing	Non-Compliant	No security policy: IT manager makes all decisions informally; 2024 breach confirms failure	No technical or organizational security controls are documented or verifiably implemented
GDPR	Art. 33 — Breach Notification	Non-Compliant	2024 breach of 12,000 records was never reported to any supervisory authority	Confirmed existing violation; 72-hour notification window was missed with no procedure in place
GDPR	Art. 37 — Data Protection Officer	Non-Compliant	No CISO appointed; IT manager handles all security informally alongside other duties	DPO not appointed despite mandatory requirement for large-scale financial data processing

Saudi PDPL	Art. 5 — Lawful Basis and Consent	Non-Compliant	No consent records, no contract-basis documentation for any processing activity	All Saudi resident data processing is legally undocumented and unjustified
Saudi PDPL	Art. 9 — Data Minimization	Non-Compliant	No data minimization policy: no justification for data categories collected	Scope of data collected has never been assessed against the minimum-necessary principle
Saudi PDPL	Art. 12 — Data Subject Rights	Non-Compliant	No request portal, no designated contact, no response procedure exists	500,000+ customers cannot exercise rights; all requests would go entirely unprocessed
Saudi PDPL	Art. 15 — Security Measures	Non-Compliant	No security policy, no CISO, undocumented cloud security; 2024 breach confirms failure	No documented technical or organizational security controls proportionate to data sensitivity
Saudi PDPL	Art. 20 — Breach Notification to SDAIA	Non-Compliant	2024 breach of 12,000 records never reported to SDAIA within 72 hours	Confirmed existing PDPL violation — not a future risk but an actual breach of the law
Saudi PDPL	Art. 30 — Cross-Border Transfer Controls	Non-Compliant	Cloud provider location undocumented; no data residency confirmation exists	Saudi resident data may be stored outside KSA without authorization or safeguards

Table 2 shows the compliance status of NoorPay in both standards. The CISO Assistant was employed in conducting the formal compliance mapping on both GDPR and Saudi PDPL (see Appendix B, Figures 4 to Figure 14). NoorPay is Non-Compliant with all 12 requirements tested in both laws.

2.3 Three Most Critical Gaps

Below is the list of the top three gaps, which reflect the most important and high-risk compliance violations by NoorPay in terms of their seriousness, regulatory enforcement potential, and potential impact.

Critical Gap 1 — Unreported Data Breach (GDPR Art. 33 + PDPL Art. 20)

Consequence: It is the most severe issue of compliance since it has occurred not in the future but currently exists as a confirmed legal violation according to both acts. According to the information provided, the data breach incident in 2024 involving 12,000 customers' personal data has never been reported to the competent regulatory authorities of the EU or Saudi Arabia within 72 hours after its discovery. Penalties for such a violation according to GDPR can amount to up to 2% of the company's turnover worldwide.

Recommendation: Submit a retroactive breach notification to the SDAIA immediately through their designated notification website. In parallel, compile and submit the breach notification documentation to the appropriate supervisory authority within the EU. The notification shall contain type of breach, types and quantity of data compromised (12,000 data entries: account numbers, transaction logs, identification documents), possible ramifications for the data subjects, and the remediation steps being undertaken.

Implementation Priority: Urgent (0–1 months). Each passing day without a breach notification further violates the regulation and exposes the company to potential penalties.

Critical Gap 2 — No Documented Lawful Basis (GDPR Art. 6 + PDPL Art. 5)

Consequence: In absence of any legal justification in writing, all of NoorPay's data processing becomes illegal under both regulations. Regulators may issue a processing cessation order, thereby immediately halting all payment processing services of 500,000 transactions per day until compliance can be shown. This poses an existential threat, not simply a penalty. This is the first thing that GDPR or PDPL auditors will ask.

Recommendation: Task the Compliance Officer to establish the Records of Processing Activity (RoPA) register in next 30 days. For each process activity — from payment processing to identity verification to transaction record keeping — record the legal justification, categories of data collected, duration, and any third-party sharing. This is purely a documentation process and does not require any technological intervention.

Implementation Priority: Immediate (0-1 month). The RoPA is the foundation of all other compliance work.

Critical Gap 3 — No Security Measures (GDPR Art. 32 + PDPL Art. 15)

Outcome: As can be seen from the above gap, the 2024 data breach led to 12,000 unauthorized access cases to customer records. Without addressing this gap, data breaches will always happen. Each incident entails notification duties, fines, and losing customers. A fintech company cannot

withstand security failure in this case because losing customer trust is equivalent to putting out of business.

Suggestion: As the first step, mandatory MFA must be established within cloud accounts and internal systems. Using only one technology, the company eliminates credential-stuffing and phishing. Simultaneously, it prepares a one-page Cloud Security Policy designating the IT Manager responsible for implementation.

Implementation Urgency: Immediate (0–1 month) for MFA. Short-term (1–3 months) for the security policy.

2.4 CISO Assistant — Compliance Mapping

CISO Assistant tool was utilized to carry out compliance audits on both the GDPR framework and the Saudi PDPL framework with respect to the NoorPay profile. In this case, the GDPR audit employed the GDPR.EU framework checklist for the data controller, while the Saudi PDPL framework was a customized Saudi PDPL framework incorporated via YAML library following the official Saudi Data & Al Authority guidelines. All requirements in both frameworks were marked as non-compliant.



Figure B-1: GDPR compliance audit overview in CISO Assistant showing Non-Compliant status across assessed requirements.

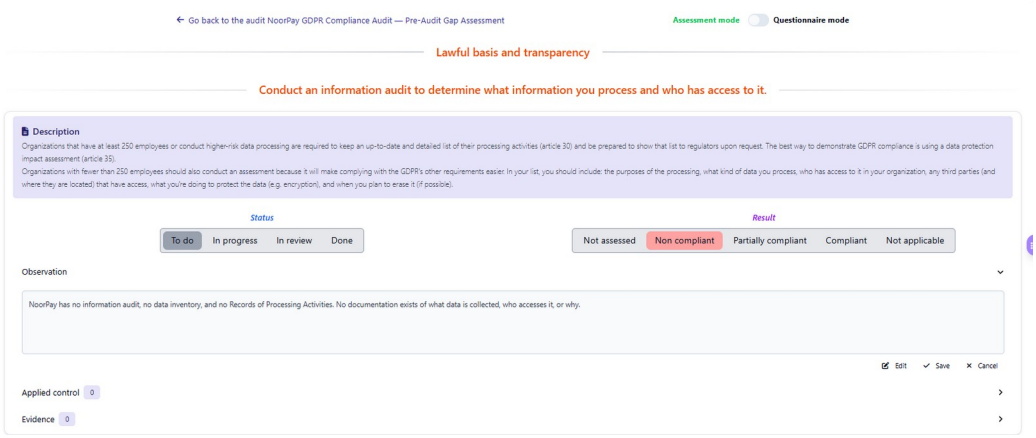


Figure B-2.1: GDPR checklist requirements in CISO Assistant showing all six assessed requirements as Non-Compliant with observations.

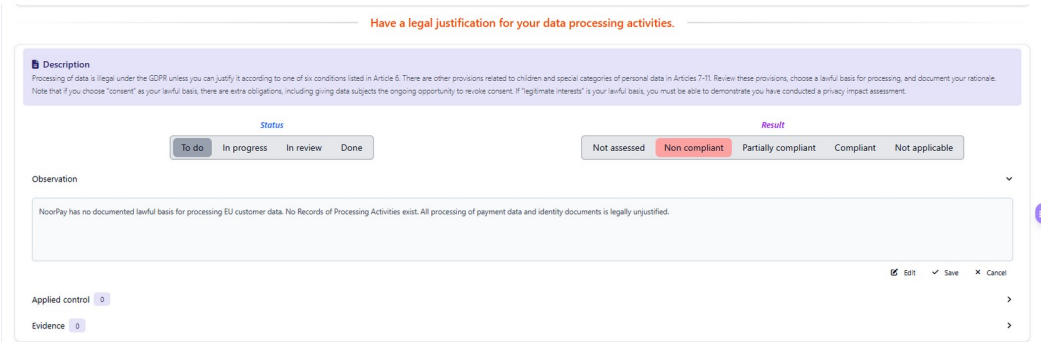


Figure B-2.2: GDPR Art. 6 - Lawful Basis for Processing assessed as Non-Compliant in CISO Assistant; NoorPay has no documented legal basis for processing EU customer data.

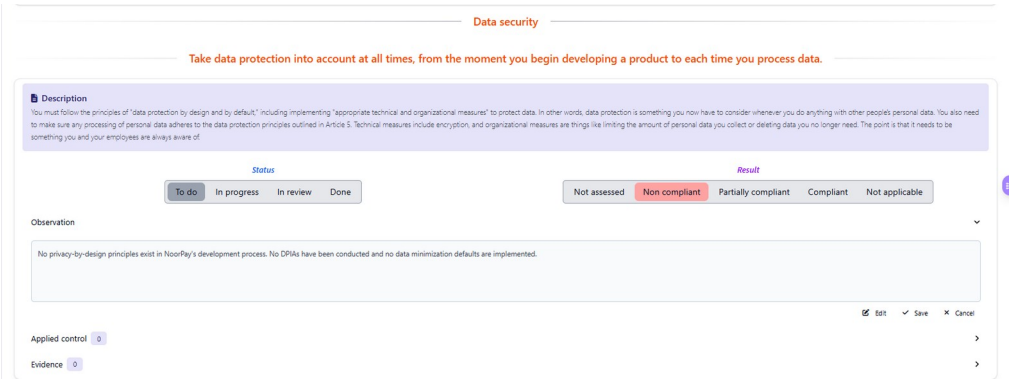


Figure B-2.3: GDPR Art. 25 / Data Security - Privacy by Design assessed as Non-Compliant; no DPIAs conducted and no data minimization defaults are implemented.

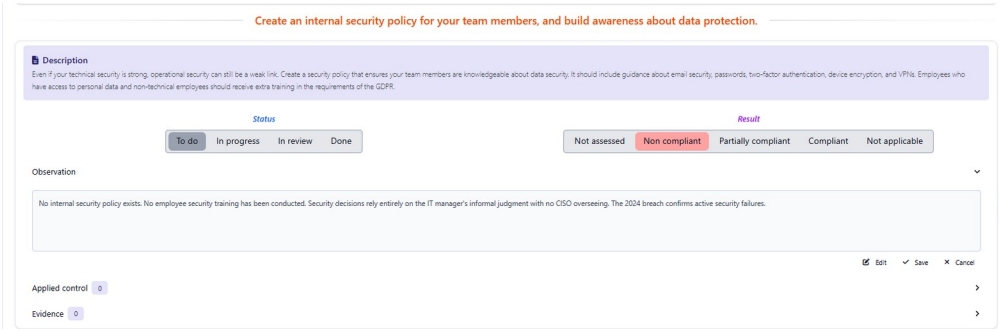


Figure B-2.4: GDPR Art. 32 - Security Measures assessed as Non-Compliant; NoorPay has no internal security policy and no employee data-protection training program.

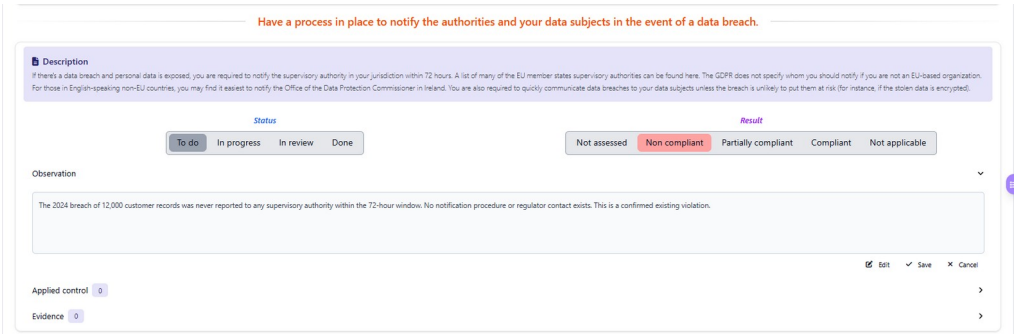


Figure B-2.5: GDPR Art. 33 - Breach Notification assessed as Non-Compliant; the 2024 breach of 12,000 records was never reported to a supervisory authority within 72 hours.

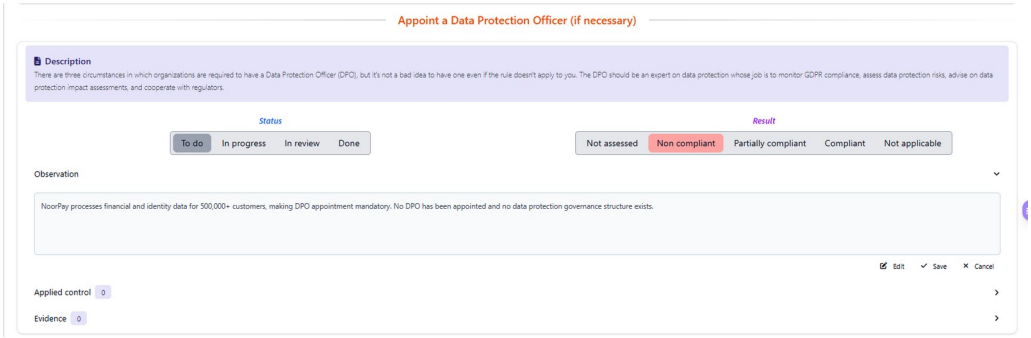


Figure B-2.6: GDPR Art. 37 - Data Protection Officer assessed as Non-Compliant; NoorPay processes large volumes of financial and identity data but has not appointed a DPO.

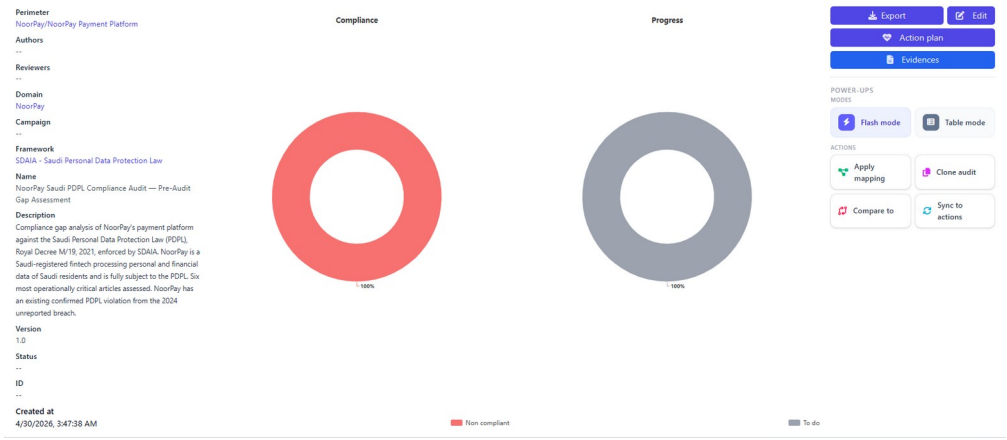


Figure B-3: Saudi PDPL compliance audit overview in CISO Assistant showing 100% Non-Compliant result across all six assessed articles.

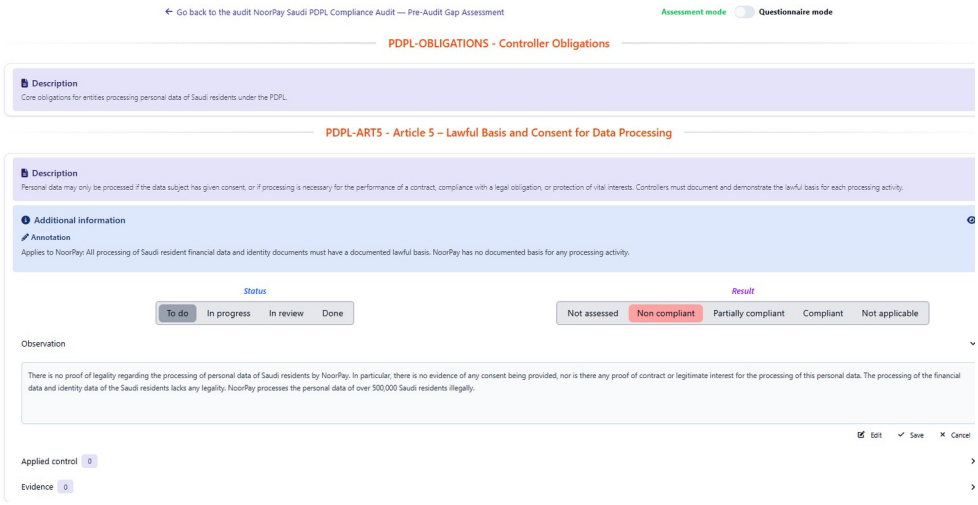


Figure B-4.1: Saudi PDPL articles in CISO Assistant showing all six articles assessed as Non-Compliant with observations visible.

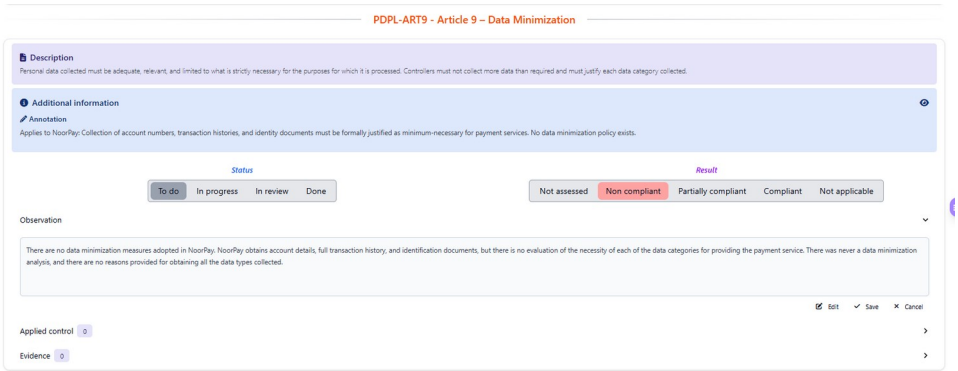


Figure B-4.2: Saudi PDPL Art. 9 - Data Minimization assessed as Non-Compliant; NoorPay collects account numbers, transaction histories, and identity documents with no formal necessity justification.

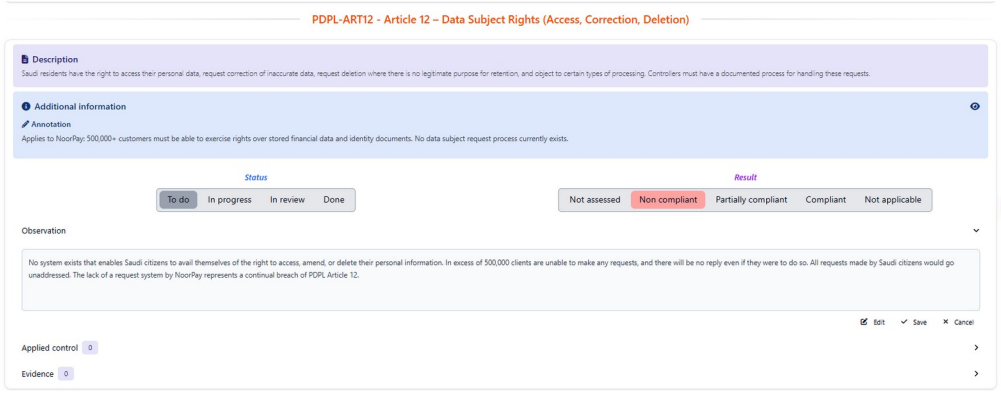


Figure B-4.3: Saudi PDPL Art. 12 - Data Subject Rights (Access, Correction, Deletion) assessed as Non-Compliant; no mechanism exists for 500,000+ customers to exercise their rights.

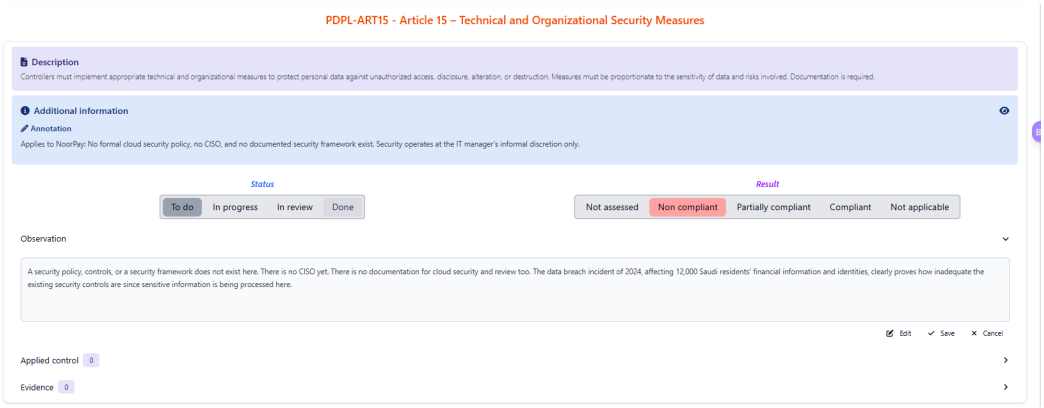


Figure B-4.4: Saudi PDPL Art. 15 - Technical and Organizational Security Measures assessed as Non-Compliant; no cloud security policy, no CISO, and no documented security framework exist.

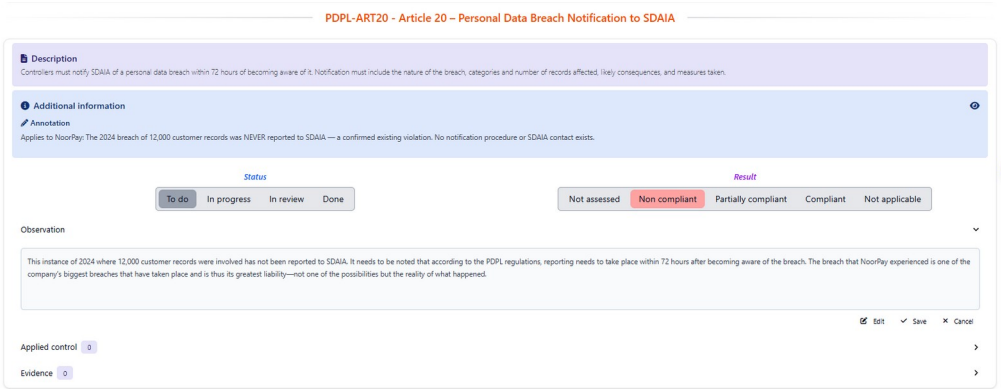


Figure B-4.5: Saudi PDPL Art. 20 - Breach Notification to SDAIA assessed as Non-Compliant; the 2024 breach of 12,000 records was never reported to SDAIA within the 72-hour window.

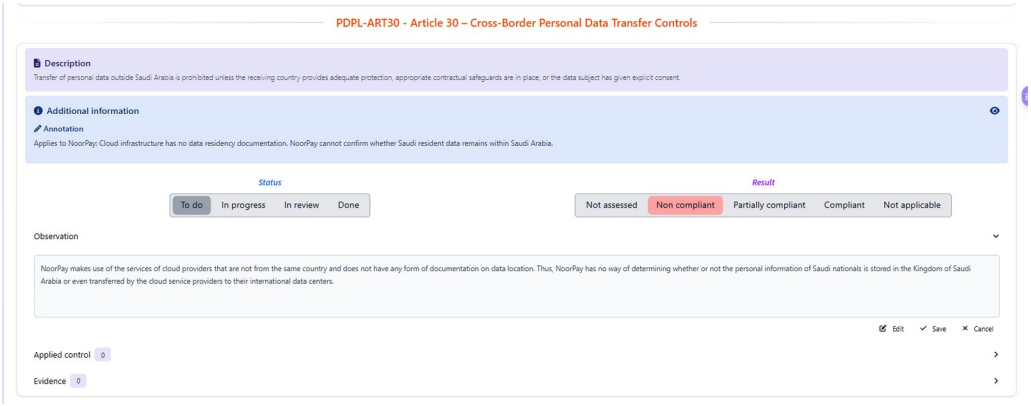


Figure B-4.6: Saudi PDPL Art. 30 - Cross-Border Data Transfer Controls assessed as Non-Compliant; NoorPay uses third-party cloud infrastructure with no data residency documentation.

3. Incident Response Plan

The following is an IRP document drafted for NoorPay regarding the data breach incident in 2024 wherein 12,000 customers' records were unauthorizedly accessed. The IRP plan is designed to help address any such incidents that may happen in the future involving unauthorized access to customers' financial data. The IRP is based on NIST SP 800-61 Rev. 2 which covers four phases of incident response, including Preparation, Detection and Analysis, Containment/Eradication/Recovery, and Post-Incident Activities.

3.1 Preparation

3.1.1 Incident Response Team

As there is no CISO at NoorPay, IRT members will be chosen from current employees along with outside legal counsel. Table 3 explains IRT organizational structure.

Table 3: NoorPay Incident Response Team

Role	Assigned To	Responsibilities	Escalation Path
Incident Commander	IT Manager	Declares incidents, coordinates all response actions, makes containment decisions, owns the incident timeline	Escalates to CEO if breach exceeds 1,000 records or regulatory notification is required
Compliance and Notification Lead	Compliance Officer	Tracks GDPR and PDPL 72-hour notification deadlines, drafts regulator communications, contacts SDAIA and EU supervisory authority	Reports to IT Manager; immediately engages External Counsel for legal review of all notifications
Customer Communication Lead	Customer Support Lead	Manages all customer-facing communications, prepares notification templates, handles customer enquiries post-	Reports to Compliance Officer; escalates all media enquiries directly to CEO

		breach	
Legal Advisor	External Counsel (retained)	Reviews all external communications before release, advises on notification obligations, manages regulatory correspondence	Engaged by Compliance Officer within 2 hours of incident confirmation

3.1.2 Preparation Measures

Four specific preparation measures NoorPay must implement before any incident occurs:

1. Log Retention Policy for Cloud Access Logs: Third-party cloud access logs must be retained for a minimum of 12 months. Without log retention, it will be impossible to conduct an investigation into any incidents involving the data of NoorPay as evidenced by the 2024 incident where it was resolved but never investigated due to no logs available.
2. List of Regulator Contacts (Offline Version): Create a physical document and maintain a digital copy listing the website and email address of SDAIA for breach notifications, along with contacts of the applicable EU supervisory authority. This document should be available even if NoorPay's system is compromised during the incident.
3. Breach Notification Templates Approved in Advance: Prepare and have legal approval for breach notification templates in advance, namely, one for SDAIA (Arabic version) and one for the EU supervisory authority (English version). The pre-approved notification templates save the time required for creating templates and seeking legal approval within the 72-hour period.

Table of Severity Levels: The levels of severity need to be identified in advance so that the IT manager can classify the severity level and proceed accordingly.

3.2 Detection and Analysis

3.2.1 Indicators of Compromise

Three IoCs that would indicate a data breach in the NoorPay payment system specifically:

IoC 1 — Bulk Export of Data During Off-Hours: A bulk data export request from the NoorPay cloud storage or database during off-hours (between 10 pm and 6 am AST), coming from an IP address outside NoorPay's office LAN and recognized cloud services, could be a sign of data exfiltration activity.

IoC 2 — Cred Stuffing Attack Followed by Login Success: Ten or more failed login attempts to an employee's personal account or to NoorPay's administrator panel followed by a successful login attempt from an unfamiliar location or IP, suggesting successful credential stuffing or targeted brute force attack.

IoC 3 — Unusual Activity with Transaction History APIs: A large number (>100) of programmatic calls to the transaction history endpoints made within a short period (<5 minutes), using an employee service account that is usually not used for such activities, can be a sign of data breach.

Table 4: NoorPay Incident Severity Classification

Severity	Criteria for NoorPay	Required Response Time
Low	Suspicious activity detected but no confirmed unauthorized access; fewer than 10 accounts involved	Investigate within 24 hours; document in incident log
Medium	Confirmed unauthorized access; 10–499 records affected; no financial data or identity documents confirmed exposed	Contain within 4 hours; notify IT Manager immediately; begin preliminary documentation
High	500–11,999 records exposed; financial data or identity documents involved	Contain within 2 hours; engage external counsel; prepare regulator notification draft
Critical	12,000+ records exposed, or any breach involving transaction histories AND identity documents together, or system-wide compromise	Immediate containment; activate full IRT within 1 hour; notify SDAIA and EU authority within 72 hours

3.3 Containment, Eradication, and Recovery

3.3.1 Immediate Containment — First Two Hours

These steps should be completed within two hours of identifying the breach. Table 5 provides a timeline for containment with the required activities and their respective responsible parties.

Table 5: Two-Hour Containment Timeline

Time	Action	Responsible
0:00	Incident confirmed. IT Manager declares incident and records the exact time of discovery. This timestamp starts the 72-hour regulatory notification clock under both PDPL and GDPR.	IT Manager
0:15	Revoke all active API tokens and cloud IAM credentials for affected service accounts via the cloud provider's IAM console. Do not shut down systems — logs must be preserved for forensic analysis.	IT Manager
0:30	Apply deny-all access policy to affected cloud storage buckets, preventing further data access while preserving all logs and data intact for investigation.	IT Manager

0:45	Compliance Officer notifies External Counsel. Begins drafting SDAIA notification. Calculates exact 72-hour deadline from time of discovery and records it in the incident log.	Compliance Officer & External Counsel
1:00	Customer Support Lead prepares internal staff briefing. No external statements are released without External Counsel approval at this stage.	Customer Support Lead
1:30	IT Manager captures and preserves all access logs. Takes cloud infrastructure snapshots for forensic analysis. Documents all actions taken with timestamps.	IT Manager
2:00	Full IRT call convened. Confirm severity classification. Confirm notification drafts in progress. Decide whether to engage external forensic firm.	Full IRT

3.3.2 Eradication and Recovery

Once containment is achieved, NoorPay will be required to perform the following activities before any restoration can take place:

4. Perform log analysis to find out the exact attack vector – which credentials were used, what endpoints were accessed, which data was accessed, and how much.
5. Close the vulnerability exploited by the attacker before any restoration takes place. This activity involves rotating the compromised credentials, addressing the cloud misconfiguration issue, and closing the exact access point through which the breach occurred.
6. Search the rest of the cloud storage in case any other attack vectors were present to ensure that the extent of the breach is known and properly contained.
7. Restore any affected service from the latest well-known good backup only once the attack vector is completely closed.

The restored services must be monitored for the following 48 hours before going back to regular operation. The IT Manager must look at the access logs daily.

3.3.3 Regulatory Notification Obligations

Table 6 presents the regulatory notification requirements triggered by a breach of this type under both GDPR and Saudi PDPL.

Table 6: Regulatory Notification Obligations

Regulation	Who to Notify	Deadline	Required Content
Saudi PDPL Art. 20	SDAIA via official notification portal	Within 72 hours of awareness	Nature of breach, data categories affected, number of records, likely consequences, measures taken or planned
GDPR Art. 33	Lead EU supervisory authority (authority of the EU member state where most affected EU customers are based)	Within 72 hours of awareness	All PDPL content plus: DPO contact details if appointed, categories and approximate number of data subjects affected
GDPR Art. 34	Affected EU individuals directly	Without undue delay where high risk to rights and freedoms	Plain language breach description, NoorPay contact point, likely consequences, steps NoorPay is taking

3.4 Post-Incident Activity

3.4.1 Post-Incident Review Template

Table 7 presents the post-incident review template NoorPay should use after any future breach. This template must be completed within two weeks of incident closure.

Table 7: Post-Incident Review Template

Incident ID	[e.g. INC-2026-001]
Date of Incident	[Date]
Date of Review	[Date — within 2 weeks of closure]
Reviewed By	IT Manager, Compliance Officer, External Counsel
Severity Level	[Low / Medium / High / Critical]
Section 1 — Incident Timeline	
Timestamp	Event
Section 2 — Root Cause Analysis	
What was the initial attack vector?	[Entry]
What specific control failure allowed the breach?	[Entry]
Why was detection delayed?	[Entry]
Section 3 — Lessons Learned	
What worked well during response?	[Entry]
What failed or was delayed?	[Entry]
What control would have prevented or reduced the breach?	[Entry]
Section 4 — Corrective Actions	
Action | Owner | Priority | Deadline | Status	[Entry]

3.4.2 Linking Post-Incident Findings to the Risk Register

The results of the post-incident review should be fed straight back into NoorPay's risk register, which should be kept up to date in CISO Assistant. After every post-incident review, the IT Manager will need to make changes to the risk register as follows: If the incident corresponds to a risk scenario in the risk register, increase the likelihood rating of that risk to account for the actual event that happened; If there were any other risks discovered as part of the incident that have not yet been documented in the risk register, add them as new risk scenarios; If a recommendation from Section 4 was implemented in its entirety, decrease the likelihood or impact rating of the risk, along with including the control in the existing controls section.

Conclusion

Through this engagement, it became clear that the risk and compliance approach adopted by NoorPay is not merely inadequate – it is non-existent. In contrast to other companies, which typically focus on addressing certain gaps in their program during the process of governance, risk and compliance (GRC), our assessment showed there was no program at all – not controls, no compliance program, no breach response capabilities, and even an existing breach. The most difficult part of this assessment was deciding what finding to prioritize given that all of them were equally crucial.

Had we more time and financial capacity, we would conduct a technical evaluation of the company's cloud services to determine the real state of the encryption and access control system, rather than make an assumption based on the lack of proper documentation. Additionally, we would consult directly with SDAIA before submitting a retroactive report about the previous breach in order to navigate the current legal environment.

References

1. National Institute of Standards and Technology. (2012). SP 800-30 Rev. 1: Guide for Conducting Risk Assessments. NIST. https://doi.org/10.6028/NIST.SP.800-30r1

2. National Institute of Standards and Technology. (2012). SP 800-61 Rev. 2: Computer Security Incident Handling Guide. NIST. https://doi.org/10.6028/NIST.SP.800-61r2

3. European Parliament and Council. (2016). Regulation (EU) 2016/679 (General Data Protection Regulation). Official Journal of the European Union. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679

4. Kingdom of Saudi Arabia. (2021). Personal Data Protection Law, Royal Decree M/19. Saudi Data and AI Authority (SDAIA). https://sdaia.gov.sa/en/SDAIA/about/Documents/Personal%20Data%20Protection%20Law%20EN.pdf

5. CISO Assistant Community Edition. (2024). Open-source GRC platform. intuitem. https://github.com/intuitem/ciso-assistant-community

6. GDPR.EU. (2024). GDPR checklist for data controllers. https://gdpr.eu/checklist/

Effat University

SPRING 2026

Appendices

Appendix A — CISO Assistant Risk Assessment Screenshots

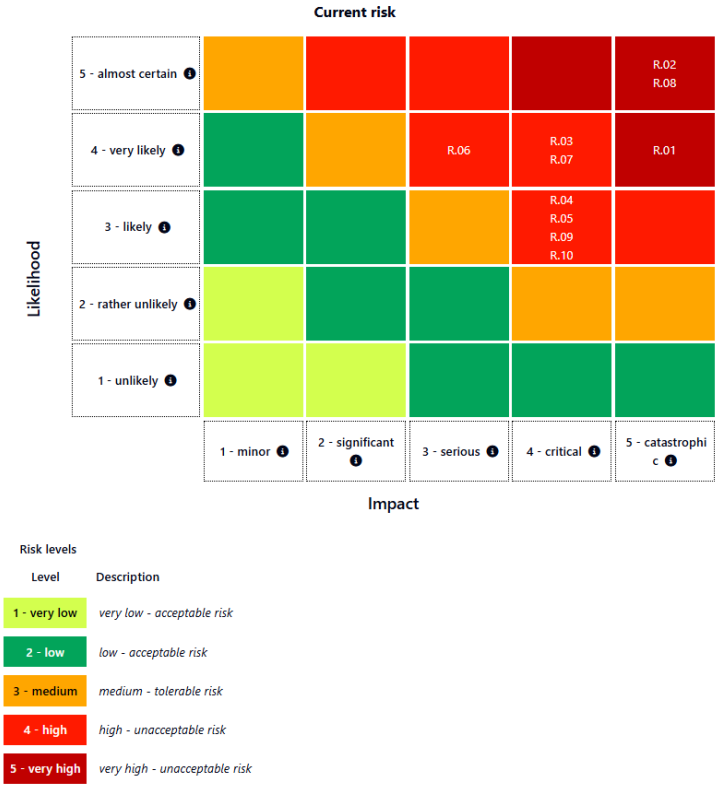


Figure A-1: NoorPay 5×5 Risk Heat Map generated in CISO Assistant showing all 10 risk scenarios plotted by likelihood and impact.

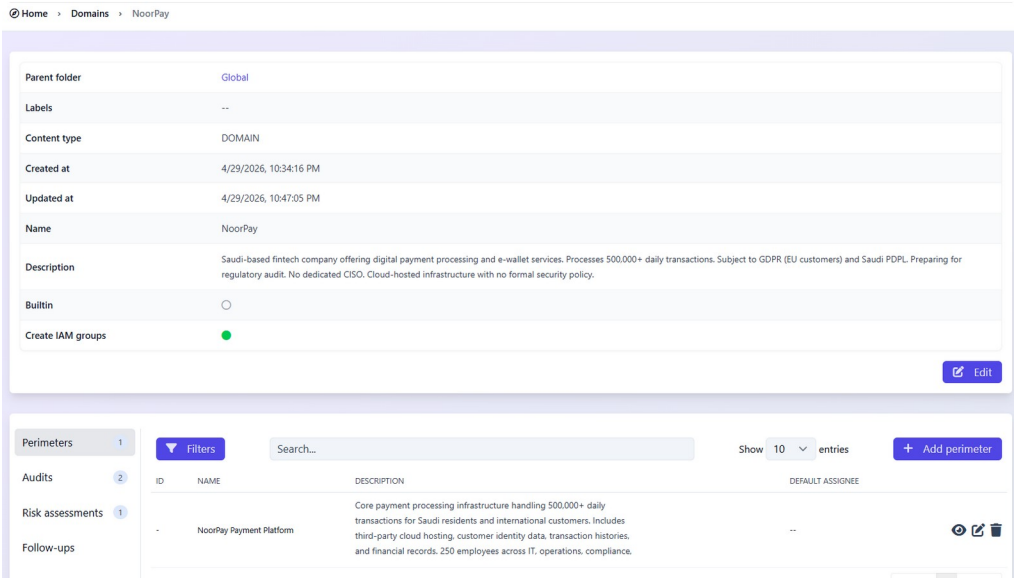


Figure A-2: NoorPay domain overview in CISO Assistant showing 1 perimeter, 2 audits, and 1 risk assessment.

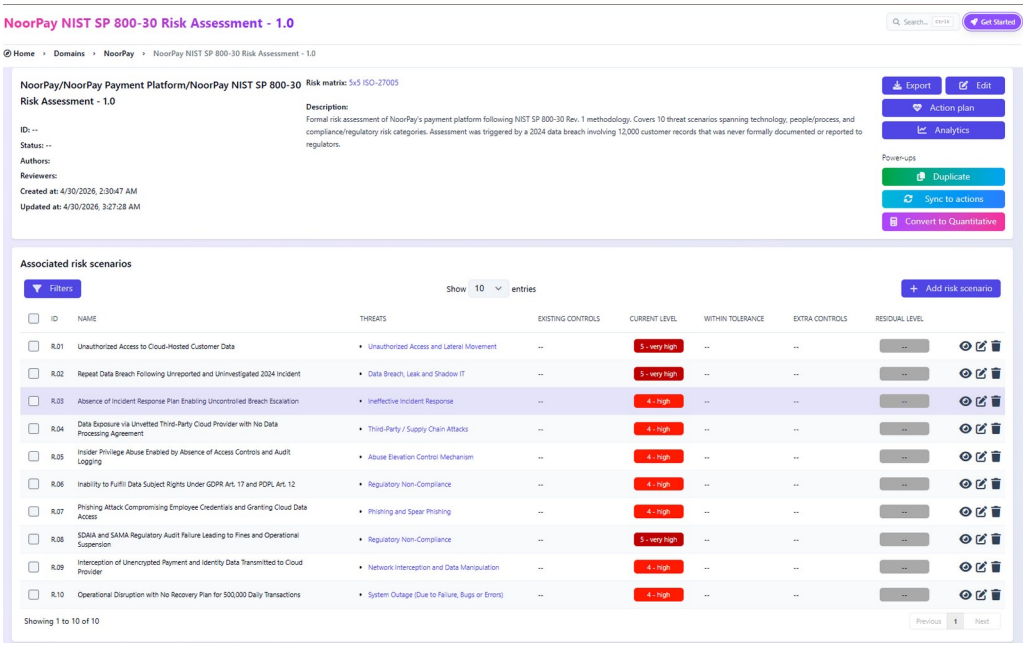


Figure A-3: All 10 NoorPay risk scenarios documented in CISO Assistant with threat classifications and risk levels.

Appendix B — CISO Assistant Compliance Audit Screenshots



Figure B-1: GDPR compliance audit overview in CISO Assistant showing Non-Compliant status across assessed requirements.

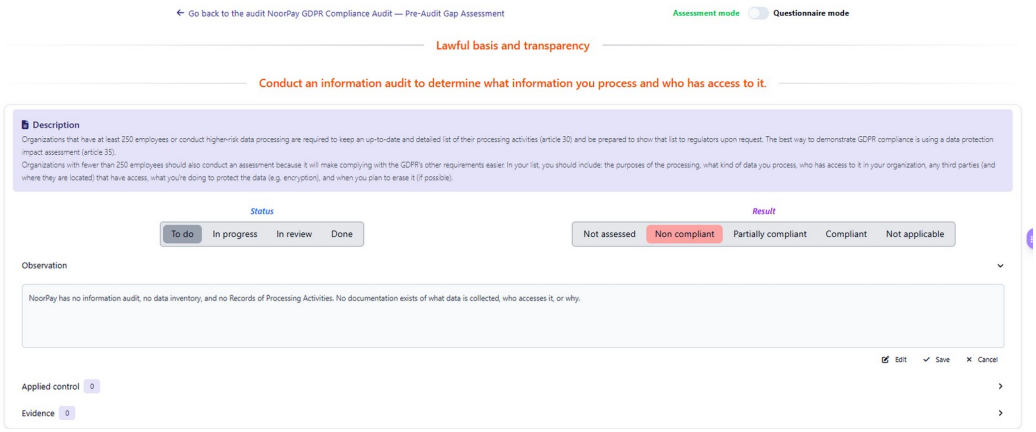


Figure B-2.1: GDPR checklist requirements in CISO Assistant showing all six assessed requirements as Non-Compliant with observations.

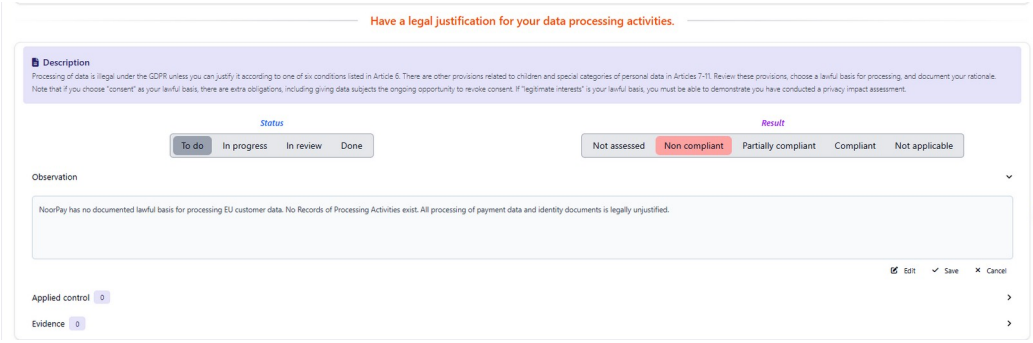


Figure B-2.2: GDPR Art. 6 - Lawful Basis for Processing assessed as Non-Compliant in CISO Assistant; NoorPay has no documented legal basis for processing EU customer data.

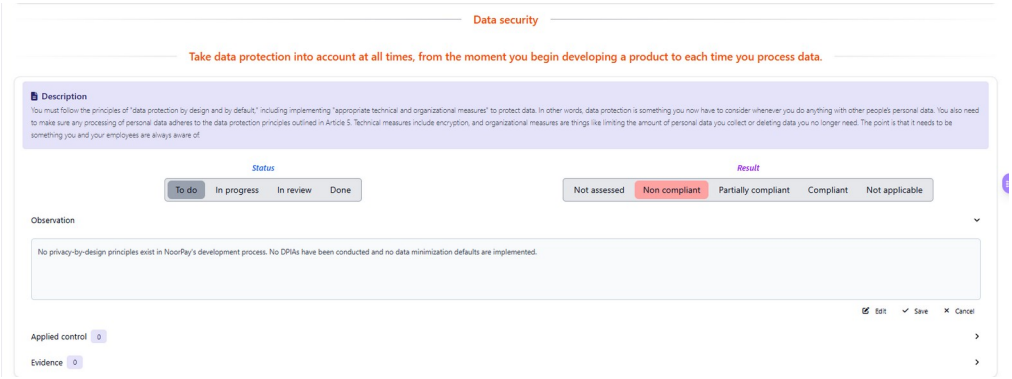


Figure B-2.3: GDPR Art. 25 / Data Security - Privacy by Design assessed as Non-Compliant; no DPIAs conducted and no data minimization defaults are implemented.

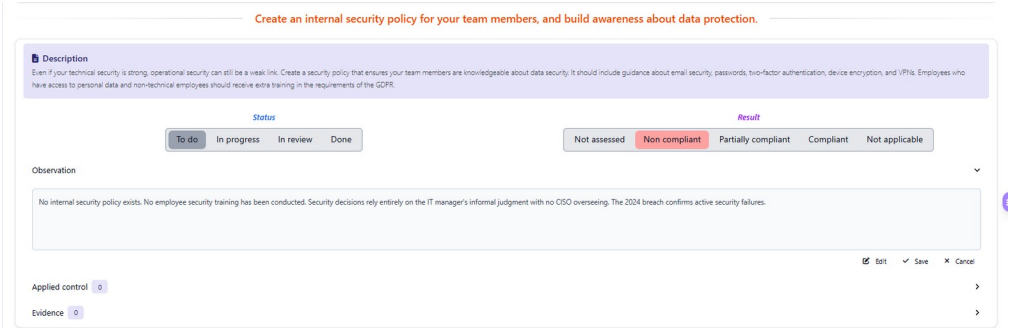


Figure B-2.4: GDPR Art. 32 - Security Measures assessed as Non-Compliant; NoorPay has no internal security policy and no employee data-protection training program.

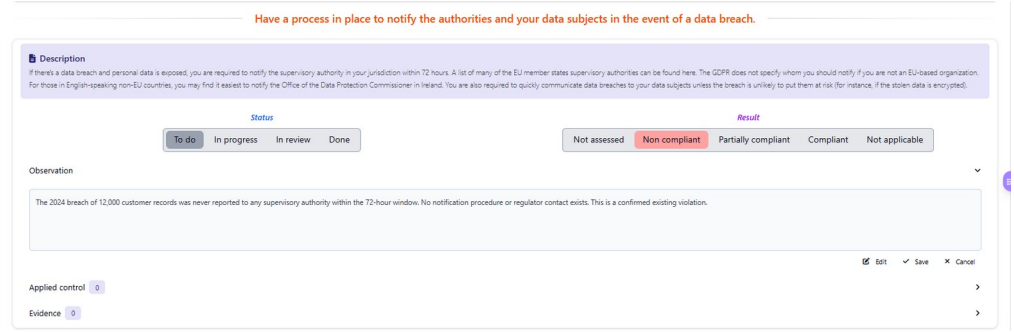


Figure B-2.5: GDPR Art. 33 - Breach Notification assessed as Non-Compliant; the 2024 breach of 12,000 records was never reported to a supervisory authority within 72 hours.

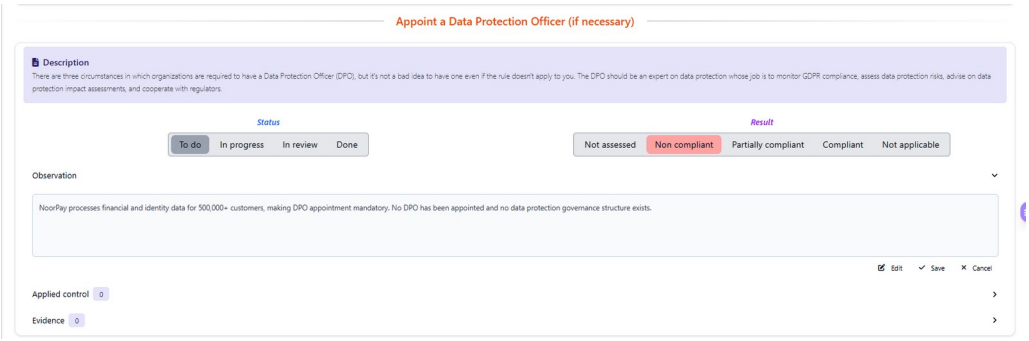


Figure B-2.6: GDPR Art. 37 - Data Protection Officer assessed as Non-Compliant; NoorPay processes large volumes of financial and identity data but has not appointed a DPO.



Figure B-3: Saudi PDPL compliance audit overview in CISO Assistant showing 100% Non-Compliant result across all six assessed articles.

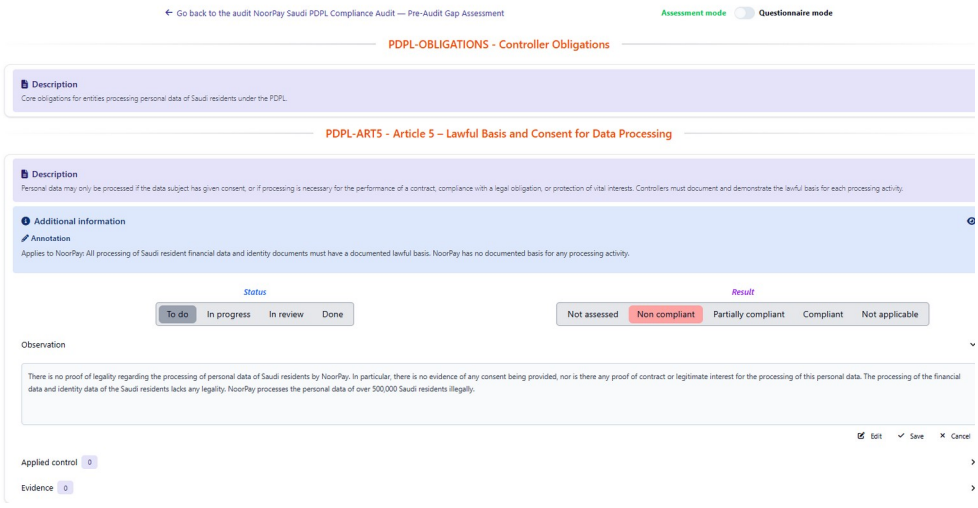


Figure B-4.1: Saudi PDPL articles in CISO Assistant showing all six articles assessed as Non-Compliant with observations visible.

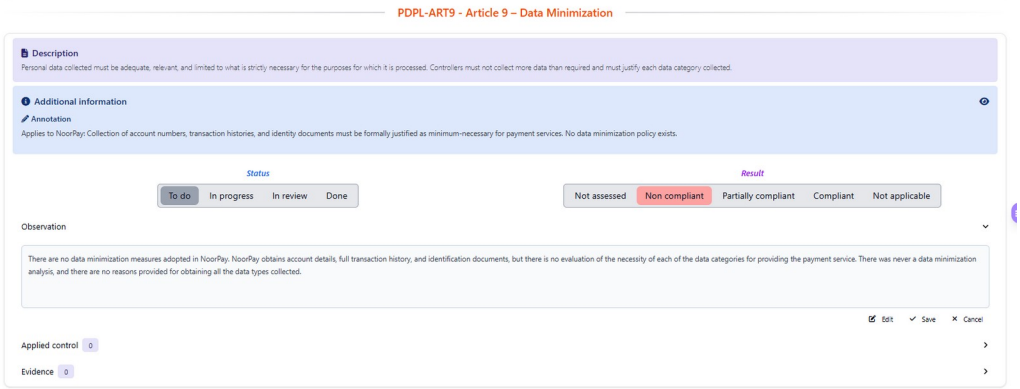


Figure B-4.2: Saudi PDPL Art. 9 - Data Minimization assessed as Non-Compliant; NoorPay collects account numbers, transaction histories, and identity documents with no formal necessity justification.

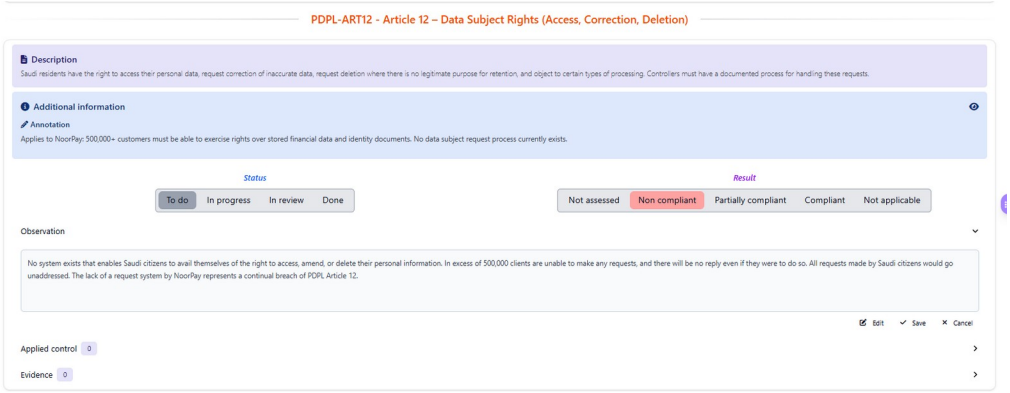


Figure B-4.3: Saudi PDPL Art. 12 - Data Subject Rights (Access, Correction, Deletion) assessed as Non-Compliant; no mechanism exists for 500,000+ customers to exercise their rights.

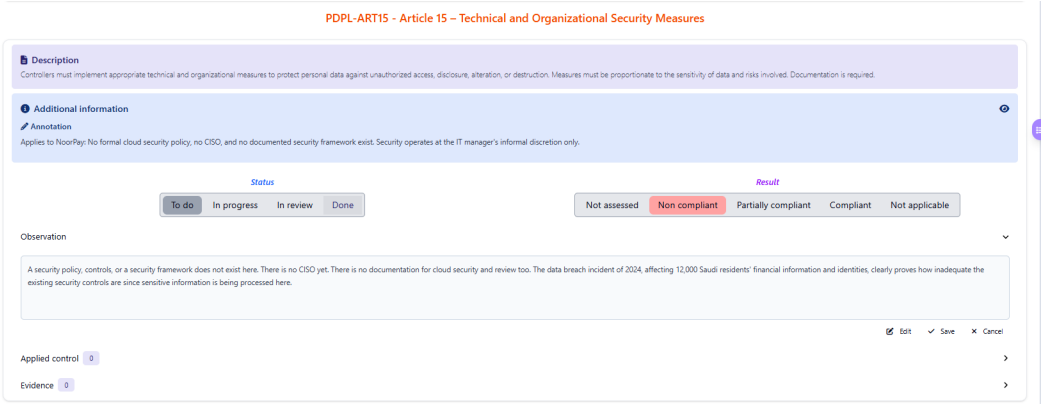


Figure B-4.4: Saudi PDPL Art. 15 - Technical and Organizational Security Measures assessed as Non-Compliant; no cloud security policy, no CISO, and no documented security framework exist.

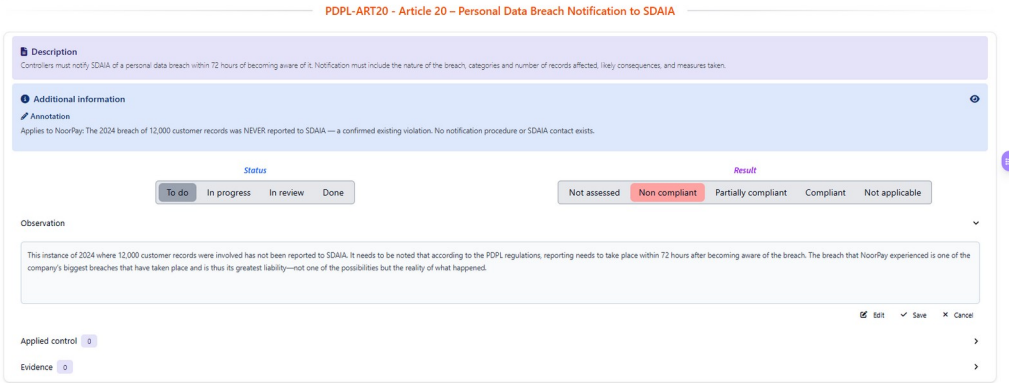


Figure B-4.5: Saudi PDPL Art. 20 - Breach Notification to SDAIA assessed as Non-Compliant; the 2024 breach of 12,000 records was never reported to SDAIA within the 72-hour window.

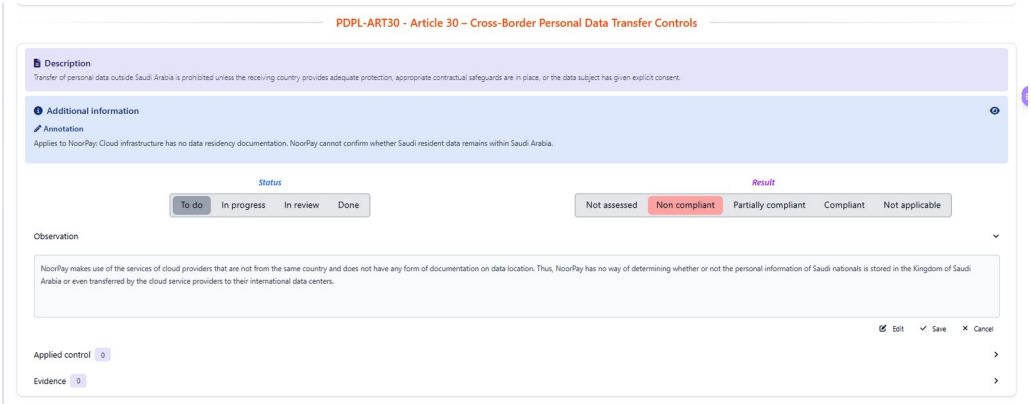


Figure B-4.6: Saudi PDPL Art. 30 - Cross-Border Data Transfer Controls assessed as Non-Compliant; NoorPay uses third-party cloud infrastructure with no data residency documentation.